Université de Perpignan Année 2025
Licence 3 Informatique C. Negre

Contrôle Terminal

Sécurité Informatique

Recommandations:

- Durée : 2 heures.
- Seuls les documents fournis sont autorisés.
- Vous rendrez un fichier numérique contenant les réponses aux questions, je dois pouvoir copier-coller vos entrées pour les tester lors de la correction.
- Pour l'exercice 1, vous donnerez les sorties du terminal que vous obtenez. Je tiendrai compte des réponses non totalement fonctionnelle, mais donnez des explications !

Exercice 1. On considère le code `quizz.c` qui implémente un jeu de quizz de culture générale. Une série de 5 questions sont posées et le score du joueur augmente de 10 si il répond correctement aux 5 questions. Vous avez ci-dessous la fonction `ask_questions` qui pose 5 questions aléatoirement. L'exécutable `quizz` a été compilé avec les options `-g -fno-stack-protector -no-pie`.

```
int ask_questions() {

  int correct=0;
  int i;
  int k;
  char asw[32];

  for(i=n;i>0;i--)
    {
      k=((unsigned int) rand());
      printf("%s\n",questions[k & 63]);
      printf("answer:");

      gets(asw);

      if( strcasestr(asw,correct_answers[k & 63]) != NULL )
        {
          printf("Yes! good answer\n");
          correct++;
        }
      else
        {
          printf(asw);
          printf("is not correct!");
          printf("the answer was : '%s'\n",correct_answers[k & 63]);
        }
    }
  return(correct);
}
```

1. Analysez l'exécutable `quizz` et expliquez comment sont organisées en mémoire les variables locales de la fonction `ask_questions`.

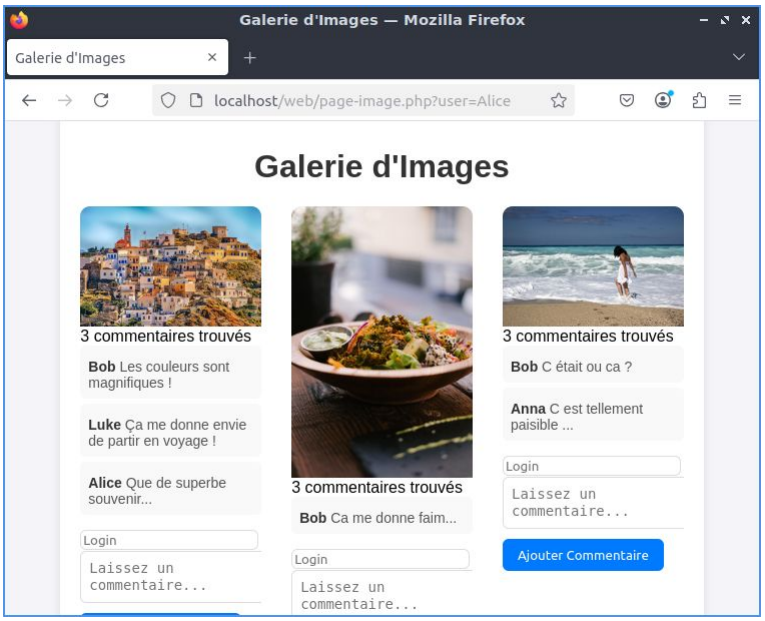
2. Proposez un débordement (uniquement sur les variables locales de la fonction `ask_questions`) qui vous assure que les réponses soit considérées comme correctes à au moins 4 questions sur les 5 premières questions et à toutes les questions pour tous les groupes de 5 questions qui suivent.

3. Expliquez comment connaître les valeurs de SavedRIP et SavedRBP. Expliquez comment en déduire les adresses du début des codes des fonctions `main` et `ask_questions`.

4. Expliquez comment revenir après l'appel à `ask_questions` directement sur l'instruction `score+=10` du `main`, tout en s'assurant que la base de la pile soit valide.

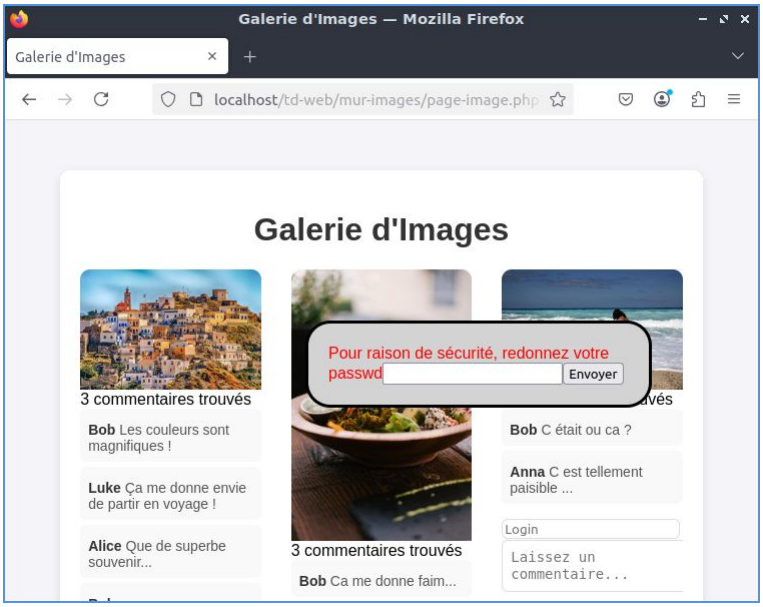
Exercice 2. Les fichiers du site web sont dans le répertoire `web` sur le bureau de la machine virtuelle. Notez qu'il faut que vous chargiez la base de données (faire `source bd.sql`). Pour se loguer dans sql faire `mysql -u l2info -p` dans le terminal et sélectionner la base de données l2info.

On considère d'abord la page web `http:/localhost/web/page-image.php?user=Alice` qui affiche les images de l'utilisteur Alice et des commentaires des autres utilisateurs. Vous avez un aperçu ci-dessous



1. Expliquez comment faire apparaître une fenêtre de type alert dans la page.

2. Expliquez comment faire apparaître un élément qui demande de rerentrer un mot de passe et de le transmettre via un bouton de soumission.



Notez que vous pouvez utiliser le style `.alerte` déjà présent dans cette page pour cet exploit.

3. Expliquez comment rentrez un commentaire avec un login invalide. Expliquez ce qui sera affiché sur la page suite à cet exploit.

4. On considère maintenant la page web `http:/localhost/web/liste-commentaires.php` qui permet de lister tous les commentaires postés par un des utilisateurs. Vous avez un aperçu ci-dessous:

Expliquez comment afficher la liste des emails de tous les utilisateurs à la place des commentaires.